

Interview Questions for Cyber Security

1. What is the CIA triad in cyber security?

Answer The CIA triad stands for Confidentiality, Integrity, and Availability. It is a model designed to guide policies for information security within an organization.

2. What is a firewall, and how does it work?

Answer A firewall is a network security device that monitors and filters incoming and outgoing network traffic based on security rules. It establishes a barrier between a trusted internal network and untrusted external networks.

3. Explain the difference between symmetric and asymmetric encryption.

Answer Symmetric encryption uses the same key for both encryption and decryption, while asymmetric encryption uses a public key for encryption and a private key for decryption.

4. What is a VPN, and why is it used?

Answer A VPN (Virtual Private Network) extends a private network across a public network, allowing users to send and receive data securely as if their devices were directly connected to the private network.

5. What is multi-factor authentication (MFA)?

Answer MFA is a security system that requires more than one method of authentication from independent categories of credentials to verify the user's identity.

6. What is a DDoS attack, and how can it be mitigated?

Answer A DDoS (Distributed Denial of Service) attack aims to make a service unavailable by overwhelming it with traffic from multiple sources. Mitigation techniques include rate limiting, IP blacklisting, and using CDNs and DDoS protection services.

7. What are the differences between IDS and IPS?

Answer IDS (Intrusion Detection System) monitors network traffic for suspicious activity and alerts administrators. IPS (Intrusion Prevention System) monitors network traffic and takes action to prevent threats, such as blocking malicious traffic.

8. What is phishing, and how can you protect against it?

Answer Phishing is a type of social engineering attack where attackers trick individuals into providing sensitive information. Protection methods include user education, email filtering, and implementing anti-phishing software.

9. What is the principle of least privilege?

Answer The principle of least privilege states that users and systems should have the minimum level of access necessary to perform their duties, reducing the risk of unauthorized access.

10. Explain what SSL/TLS is and how it works.

Answer SSL (Secure Sockets Layer) and its successor, TLS (Transport Layer Security), are protocols for establishing authenticated and encrypted links between networked computers. They use public-key cryptography to secure data transmission.

11. What is a zero-day vulnerability?

Answer A zero-day vulnerability is a security flaw that is unknown to the software vendor and has not been patched, leaving systems vulnerable to attacks until the flaw is fixed.

12. How does public key infrastructure (PKI) work?

Answer PKI is a framework for managing digital keys and certificates. It involves the creation, distribution, management, and revocation of digital certificates and public keys to ensure secure communication and authentication.

13. What is a man-in-the-middle (MITM) attack?

Answer A MITM attack occurs when an attacker secretly intercepts and relays messages between two parties who believe they are directly communicating with each other.

14. What is the difference between hashing and encryption?

Answer Hashing is a one-way process that transforms data into a fixed-size hash value, which cannot be reversed. Encryption is a two-way process that encodes data so that it can be securely transmitted and later decrypted.

15. What is SQL injection, and how can it be prevented?

Answer SQL injection is a code injection technique that exploits vulnerabilities in a web application's software. Prevention methods include using parameterized queries, input validation, and stored procedures.

16. Explain the concept of network segmentation.

Answer Network segmentation involves dividing a network into smaller segments to improve security and performance by limiting access to sensitive data and reducing the attack surface.

17. What is social engineering, and how can it be countered?

Answer Social engineering is the manipulation of individuals into divulging confidential information. Countermeasures include user education, awareness training, and implementing strict security policies.

18. What is a security policy, and why is it important?

Answer A security policy is a document that outlines an organization's security measures, protocols, and procedures. It is important because it provides a framework for ensuring the protection of assets and compliance with regulations.

19. How do you secure a wireless network?

Answer Securing a wireless network involves using strong encryption (like WPA3), changing default settings, disabling WPS, enabling MAC address filtering, and regularly updating firmware.

20. What is a honeypot, and what is its purpose?

Answer A honeypot is a decoy system or network set up to attract and monitor malicious activity. Its purpose is to gather intelligence about attackers and their methods.

21. Explain the concept of endpoint security.

Answer Endpoint security refers to the protection of endpoints (such as desktops, laptops, and mobile devices) from malicious threats. This includes using antivirus software, firewalls, and intrusion detection systems.

22. What are the common types of malware?

Answer Common types of malware include viruses, worms, trojans, ransomware, spyware, adware, and rootkits.

23. What is the role of a security operations center (SOC)?

Answer A SOC is a centralized unit that deals with security issues on an organizational and technical level, responsible for monitoring, detecting, responding to, and mitigating security incidents.

24. What is a security audit?

Answer A security audit is a systematic evaluation of an organization's security policies, procedures, and infrastructure to identify vulnerabilities and ensure compliance with security standards.

25. How do you perform a risk assessment?

Answer Performing a risk assessment involves identifying assets, evaluating potential threats, determining vulnerabilities, assessing the impact and likelihood of risks, and implementing mitigation strategies.

26. What is the difference between black-box and white-box testing?

Answer Black-box testing involves testing a system without knowledge of its internal workings, while white-box testing involves testing with full knowledge of the system's architecture and code.

27. What is the purpose of a digital certificate?

Answer A digital certificate is used to verify the identity of a person, device, or organization, and to secure data transmission through encryption and digital signatures.

28. How do you implement data loss prevention (DLP)?

Answer DLP is implemented by deploying tools and strategies to detect, monitor, and prevent unauthorized access, transmission, or leakage of sensitive data, including endpoint, network, and cloud-based solutions.

29. What is penetration testing?

Answer Penetration testing, or ethical hacking, is a method of evaluating the security of a system by simulating an attack from a malicious actor to identify and fix vulnerabilities.

30. What are the different types of firewalls?

Answer Types of firewalls include packet-filtering firewalls, stateful inspection firewalls, proxy firewalls, and next-generation firewalls (NGFW).

31. What is a security incident, and how is it handled?

Answer A security incident is an event that compromises the confidentiality, integrity, or availability of information. It is handled through an incident response plan, which includes detection, containment, eradication, recovery, and lessons learned.

32. What is a buffer overflow, and how can it be prevented?

Answer A buffer overflow occurs when a program writes more data to a buffer than it can hold, potentially leading to code execution. Prevention techniques include input validation, bounds checking, and using languages with built-in protections.

33. Explain the concept of tokenization.

Answer Tokenization is the process of replacing sensitive data with unique identification symbols (tokens) that retain the essential information without compromising security.

34. What is a sandbox, and how is it used in cyber security?

Answer A sandbox is an isolated environment used to run and analyze untrusted programs or code without risking harm to the host system or network.

35. How do you secure cloud services?

Answer Secure cloud services by using encryption, implementing strong access controls, regularly auditing and monitoring activities, and following best practices for cloud security.

36. What is a security baseline?

Answer A security baseline is a set of minimum security standards and configurations that an organization adheres to in order to protect its information systems.

37. What is the difference between a virus and a worm?

Answer A virus attaches itself to a host file and requires user action to spread, while a worm is a standalone program that self-replicates and spreads without user intervention.

38. What is the purpose of a security framework?

Answer A security framework provides a structured approach for implementing, managing, and improving security practices within an organization. Examples include NIST, ISO 27001, and CIS.

39. How do you ensure compliance with data protection regulations?

Answer Ensure compliance by understanding relevant regulations, implementing necessary security controls, conducting regular audits, and training employees on compliance requirements.

40. What is the role of encryption in data protection?

Answer Encryption protects data by converting it into an unreadable format, ensuring that only authorized parties with the correct decryption key can access the original information.

41. How do you protect against insider threats?

Answer Protect against insider threats by implementing access controls, monitoring user activity, conducting background checks, and fostering a positive security culture.

42. What is the difference between data masking and data encryption?

Answer Data masking replaces sensitive information with obfuscated data for testing or analysis, while data encryption converts data into a secure format that requires a key to decrypt.

43. What are the key components of an incident response plan?

Answer Key components include preparation, identification, containment, eradication, recovery, and lessons learned.

44. What is a rootkit, and how can it be detected?

Answer A rootkit is a type of malware that hides its presence and grants unauthorized access to a computer. Detection methods include using rootkit scanners, monitoring system behavior, and checking for unauthorized modifications.

45. Explain the concept of security through obscurity.

Answer Security through obscurity relies on hiding system details to enhance security. It is generally not recommended as a primary security measure but can be used as an additional layer of defense.

46. What is the difference between an exploit and a vulnerability?

Answer A vulnerability is a weakness in a system that can be exploited, while an exploit is a piece of code or technique used to take advantage of that vulnerability.

47. How do you secure a web application?

Answer Secure a web application by implementing input validation, using HTTPS, conducting regular security testing, and following secure coding practices.

48. What is the role of a Chief Information Security Officer (CISO)?

Answer A CISO is responsible for developing and implementing an information security program, ensuring the protection of information assets, and managing security risks within an organization.

49. What is the difference between an active and a passive attack?

Answer An active attack involves direct interaction with the target system to alter or disrupt its operation, while a passive attack involves monitoring or intercepting data without altering it.

50. What are some common security protocols used in networking?

Answer Common security protocols include SSL/TLS for secure communication, IPsec for secure IP communication, and SSH for secure remote access.